Kenya DHA HMIS Developer Compliance & Testing Tracker

System: Smart Hospital v5.0 / SFU

Target Regulation: Kenya Digital Health Agency (DHA) HMIS Certification Framework (Health Information Management Procedures Regulations 2025, Form HMIS 4)

Classification: Health Information System (HIS) with integrated Electronic Medical Record (EMR)

Date Created: 2026-11-08

■ High-Level Compliance Progress Dashboard

Status	Total Items	Percentage	Description
■ **COMPLETED**	**29**	**81%**	Core clinical modules, technical security (Bcrypt, MFA, Audit Trails, Session Timeout), statutory documents (Backup Policy, DRP, BCP, IRP, VAR, PTR), System Documentation Suite (FRS/SRS, Data Dictionary, Manuals), Data Protection Suite (DPIA, Privacy & Consent Policy), and Kenya HIE Interoperability & REST API Layer (Client Registry UPI, National ID, KMHFL, Encounters, SHA Claims) fully implemented, verified, and published.
■ **IN PROGRESS**	**6**	**17%**	National ICD-10 clinical diagnosis selector, IDSR disease alerts, and DHA lab synthetic test data suite.
■ **PENDING**	**1**	**2%**	External statutory item: Facility/Vendor formal ODPC Registration Certificate issued by Office of the Data Protection Commissioner.
TOTAL	**36**	**100%**	Full certification scope across all 8 evaluation areas.

■ DHA Evaluation Scoring Weight Breakdown

```
■■■
```

■ Detailed Compliance Tracking Sheet

Section 1: Clinical & Administrative Functionality (Weight: 35%)

Task ID	Item / Feature	System Location	Verification Evidence for DHA	Developer Status
DHA-001	**Patient Registration & Master Index**	`admin/patient`	Screenshots of patient registration modal, demographic fields, guardian information, unique PID generation.	■ **COMPLETED**
DHA-002	**OPD & IPD Consultations**	`admin/patient/ipdsearch`	Clinical documentation, doctor notes, bed allocation, vitals recording, and patient discharge summaries.	■ **COMPLETED**
DHA-003	**Operation Theatre (OT)**	`admin/operationtheatre`	Surgery scheduling, surgical team allotment, consultant surgeon instructions, OT billing vouchers.	■ **COMPLETED**
DHA-004	**Laboratory & Diagnostics**	`admin/pathology` `admin/radiology`	Pathology and radiology test requests, sample collection, parameter results entry, printable test reports.	■ **COMPLETED**
DHA-005	**Pharmacy Management**	`admin/pharmacy`	Medicine stock inventory, batch expiry management, doctor prescription dispensing, itemized pharmacy bills.	■ **COMPLETED**
DHA-006	**Physiotherapy Module**	`admin/physiotherapy`	Pain scale (1-10), pain location, range of motion, session duration, doctor instructions, and **`PHYB`** billing.	■ **COMPLETED**
DHA-007	**Pediatric Module**	`admin/pediatric`	Child demographics, DOB, height, weight, temperature, clinical notes, growth monitoring, immunizations, and **`PEDB`** billing.	■ **COMPLETED**
DHA-008	**Gynaecology Module**	`admin/gynaecology`	LMP tracking, pregnancy status, obstetric history (GPA), pelvic exam notes, prescription, and **`GYNB`** billing.	■ **COMPLETED**
DHA-009	**Hospital Billing & Finance**	`admin/bill` `admin/income`	Itemized service charges, TPA/corporate insurance billing, cashier collections, receipts, and revenue reports in KES.	■ **COMPLETED**

Section 2: Information Security, Privacy & Access Control (Weight: 30%)

Task ID	Item / Feature	System Location	Verification Evidence for DHA	Developer Status
DHA-010	**Role-Based Access Control (RBAC)**	`admin/roles/permission`	Screenshots of permissions grid for 12 system roles showing `can_view`, `can_add`, `can_edit`, `can_delete`.	■ **COMPLETED**
DHA-011	**Password Hashing & Storage**	Auth Controller	Verification of Bcrypt hashing (`$2y$10$...`) using PHP `password_hash()`; zero plaintext passwords in database.	■ **COMPLETED**
DHA-012	**Session Timeout & Access Control Evidence**	`config.php` & Evidence Doc	Technical evidence document (`SEFU_HMIS_Session_Management_and_Access_Control_Evidence.md`), 7200s idle timeout, 300s session rotation, `HttpOnly` + `SameSite=Lax`, RBAC controller guards.	■ **COMPLETED**
DHA-013	**Backup Policy & Disaster Recovery Plan (DRP)**	`admin/admin/backup` & `scripts/`	Standalone Backup Policy & Configuration specification (`SEFU_HMIS_Backup_Policy_and_Configuration.md`), comprehensive DRP document (`SEFU_HMIS_Disaster_Recovery_Plan_DRP.md`), RPO <= 1h, RTO <= 2h, 3-2-1 backup topology, automated PowerShell/batch scripts, live SHA-256 backup drill verification.	■ **COMPLETED**
DHA-014	**Encryption in Transit (TLS/HTTPS)**	Web Server / SSL	SSL/TLS certificate installed on domain (`care.rofam.africa`); HTTP to HTTPS 301 redirection.	■ **IN PROGRESS**
DHA-015	**Clinical & Financial Audit Trails**	`admin/audit` / `admin/userlog`	Complete user activity logging (Insert, Update, Delete) + login history; staff ID capture, RBAC permission toggles per role (e.g. Human Resources), log tampering protection.	■ **COMPLETED**
DHA-016	**Multi-Factor Authentication (MFA)**	`site/verify_2fa` & `Mfa_model`	2FA Email OTP enforcement for Staff, Admins, and Physicians; 6-digit cryptographic token, 10-minute expiry, brute-force lockout, single-use database validation, audit trail integration.	■ **COMPLETED**

DHA-017	**Vulnerability Assessment & Penetration Testing**	Security Docs / Reports	Formal Vulnerability Assessment Report (**`SEFU_HMIS_Vulnerability_Assessment_Report_VAR.md`**) & Penetration Testing Report (**`SEFU_HMIS_Penetration_Testing_Report_PTR.md`**) against OWASP Top 10 with 0 critical/high findings.	■ **COMPLETED**
DHA-017A	**Business Continuity Plan (BCP)**	Clinical Continuity Doc	Comprehensive BCP document (**`SEFU_HMIS_Business_Continuity_Plan_BCP.md`**), clinical downtime packets, manual paper MAR, post-downtime digital reconciliation.	■ **COMPLETED**
DHA-017B	**Incident Response Plan (IRP)**	Cybersecurity / CSIRT	Formal Incident Response Plan (**`SEFU_HMIS_Incident_Response_Plan_IRP.md`**), 6-phase NIST lifecycle, Section 43 Kenya DPA 72-hour ODPC breach notification runbook.	■ **COMPLETED**

Section 3: Data Protection & Legal Compliance (ODPC Kenya)

Task ID	Item / Feature	Scope	Verification Evidence for DHA	Developer Status
DHA-018	**ODPC Registration Certificate**	Company / Legal	Proof of registration as Data Controller / Processor from Kenya ODPC (PDF <= 2MB).	■ **PENDING**
DHA-019	**Data Protection Impact Assessment (DPIA)**	Compliance	Comprehensive statutory DPIA document (**`SEFU_HMIS_Data_Protection_Impact_Assessment_DPIA.md`**) covering health data lifecycle, risk matrix, safeguards, and DPO sign-off.	■ **COMPLETED**
DHA-020	**Privacy & Patient Consent Policy**	Legal / Product	Complete policy document (**`SEFU_HMIS_Data_Protection_Privacy_and_Consent_Policy.md`**) covering patient consent intake, data subject rights, 7-year retention, disposal, and DPA.	■ **COMPLETED**

Section 4: System Architecture & Technical Documentation

Task ID	Item / Feature	Scope	Verification Evidence for DHA	Developer Status
DHA-021	**System Architecture & FRS / SRS**	Developers	Comprehensive technical and functional specification (`SEFU_HMIS_Functional_and_System_Requirements_Specification_FRS_SRS.md`) with 4-tier architecture diagram, module FRs, and stack specs.	■ **COMPLETED**
DHA-022	**User Manual & Administrator Guide**	Product / QA	Complete operational manual (`SEFU_HMIS_User_and_Administrator_Manual.md`) covering Admin configuration, RBAC delegation, MFA, backup drills, and departmental clinical workflows.	■ **COMPLETED**
DHA-023	**Database Schema & Data Dictionary**	Developers	Database architecture & entity-relationship document (`SEFU_HMIS_Database_Data_Dictionary_and_Architecture.md`) with Mermaid ER diagram and comprehensive data dictionary for all core tables.	■ **COMPLETED**

Section 5: Public Health Reporting & Disease Surveillance (Weight: 20%)

Task ID	Item / Feature	System Location	Verification Evidence for DHA	Developer Status
DHA-024	**Hospital Operational & Clinical Reports**	`admin/report`	Exported PDF/Excel reports of bed occupancy, patient visits, doctor performance, and departmental summaries.	■ **COMPLETED**
DHA-025	**Disease Surveillance & IDSR Alerts**	Custom Reporting	Aggregation of communicable and notifiable disease cases aligned with Kenya IDSR / MOH 705/706 indicators.	■ **IN PROGRESS**

Section 6: Interoperability & National Health Information Exchange (Weight: 15%)

Task ID	Item / Feature	Technical Scope	Verification Evidence for DHA	Developer Status
DHA-026	**Open REST API Layer**	API Controllers	Authenticated JSON REST API gateway (`api/v1/`) with Bearer token & `X-API-KEY` authentication, CORS, rate limiting, and audit logging. Specification: `SEFU_HMIS_Interoperability_and_REST_API_Specification.md`.	■ **COMPLETED**
DHA-027	**Kenya Client Registry (CR) Mapping**	`patients` Table	Native support for National ID and Unique Patient Identifier (`upi` / Afya ID) with bidirectional lookup, duplicate prevention, and FHIR Patient schema.	■ **COMPLETED**
DHA-028	**Master Facility (KMHFL) & Worker Registry**	System Settings	Facility MFL code (`sch_settings.kmhfl_code`) and practitioner medical board registration (`staff.council_registration_no`) linked to encounter metadata.	■ **COMPLETED**
DHA-029	**National Terminology (ICD-10)**	Clinical Notes	Standardized ICD-10 diagnosis coding linked to consultation inputs.	■ **IN PROGRESS**

Section 7: Social Health Authority (SHA) Claims Integration

Task ID	Item / Feature	Technical Scope	Verification Evidence for DHA	Developer Status
DHA-030	**SHA Member Eligibility Verification**	TPA / Insurance	API integration verifying patient SHA / SHIF member policy active status via `/api/v1/billing/patient/{id}` and `/api/v1/patients/detail/{id}`.	■ **COMPLETED**
DHA-031	**SHA Claims Preparation & Submission**	Billing / Finance	Itemized claims preparation linking diagnoses, consultations, lab tests, and medications to SHA tariffs. Endpoint: `/api/v1/billing/patient/{id}`.	■ **COMPLETED**

Section 8: Independent Laboratory Conformance Testing (Testing Phase)

This phase is executed in **Step 9** of the DHA certification workflow by an accredited testing laboratory.

Test Area	What the Accredited Lab Will Test	Test Evidence to Prepare	Status

8.1 Functional Testing	Complete end-to-end execution of: Patient intake ➔ OPD/IPD consultation ➔ Lab/Pharmacy order ➔ Discharge ➔ Cashier payment.	Step-by-step QA Test Case document with screenshots of successful runs.	■ **IN PROGRESS**
8.2 Security & Penetration Testing	Injection attacks (SQLi, XSS), privilege escalation, unauthorized API calls, broken object-level authorization (BOLA).	Hardened input validation, CSRF tokens enabled, SQL parameter binding.	■ **IN PROGRESS**
8.3 Privacy & Data Access Controls	Verifying that a receptionist cannot view doctor clinical notes or modify lab results; verifying patient consent checks.	RBAC permission matrix verification and unauthorized access denial logs.	■ **COMPLETED**
8.4 Data Quality & Integrity	Mandatory field enforcement, valid date ranges, unique identifiers, decimal currency precision, referential integrity.	Database foreign key constraints, CodeIgniter form validation rules.	■ **COMPLETED**
8.5 Staging Environment	A live, publicly accessible test environment hosted with zero real patient data.	Dedicated staging URL (e.g. `test.care.rofam.africa`) seeded with 20+ synthetic patients.	■ **IN PROGRESS**

■■ Immediate Developer Action Plan (Priority Checklist)

1. **[ ] Enforce HTTPS / TLS 1.3:** Configure web server virtual host to reject unencrypted HTTP traffic.
2. **[ ] Populate Synthetic Test Data:** Insert 20 realistic test patients (covering adult, pediatric, gynaecology, and surgical cases) into the staging database.
3. **[ ] Export RBAC Matrix:** Capture full-screen screenshots of `admin/roles/permission` for all 12 roles.
4. **[ ] Compile Technical PDF Pack (Max 2MB per file):**

- System Architecture Diagram & Technical Specification.
- User & Administrator Manual.
- Database Schema & Data Dictionary.

5. **[ ] Review API Endpoints:** Ensure REST endpoints for Patient Search, Consultation Records, and Billing are documented with Swagger/Postman for the DHA lab testing team.

■ File Locations

- **Excel-Compatible CSV Sheet:** `DHA_HMIS_Developer_Compliance_Tracker.csv`
- **Full Markdown Tracker:** `DHA_HMIS_Developer_Compliance_Tracker.md`
- **Documentation Copy:** `documentation/DHA_HMIS_Developer_Compliance_Tracker.md`